Name: Soham Haidas Gaikwad
UID: 2024800030
Batch: A2

EXPERIMENT:

Risk Mitigation, Monitoring and Management Plan Development

LABORATORY REPORT SUBMISSION

Case Study: Green-Finance: A Real-Time Energy Observability Framework for Sustainable Financial Microservices

1. Introduction (Brief Overview of the Case Study)

Green-Finance is a real-time energy observability framework designed for sustainable financial microservices. Modern banking architectures execute millions of inter-bank fund transfers daily without visibility into the underlying computational energy consumption or Scope 2 greenhouse gas emissions. The Green-Finance platform addresses this challenge by combining a core banking transaction engine with CNCF Kepler (Kubernetes-based Efficient Power Level Exporter), Linux eBPF kernel profiling, Prometheus metrics scraping, and Grafana visualization dashboards.

For each banking transfer executed via FastAPI and recorded in an atomic double-entry ledger, the system attributes CPU and DRAM Joules, calculates equivalent CO2 emissions using the official Central Electricity Authority (CEA) of India national grid factor (713.0 gCO2/kWh), and timestamps the transaction with a SHA-256 cryptographic audit hash. The purpose of this Risk Mitigation, Monitoring, and Management (RMMM) Plan is to identify, assess, control, and monitor potential architectural, security, regulatory, and operational risks across the platform's development and production deployment.

2. Methodology (Approach Used for Risk Identification and Analysis)

The risk management approach aligns with PMBOK (7th Edition), ISO 31000:2018, and NIST SP 800-30 guidelines. Risks were identified by breaking down the system into five core functional domains: (1) Core Banking Payment Processing, (2) Hardware Telemetry & eBPF Profiling, (3) Database Ledger Consistency, (4) Cloud Container Deployment, and (5) Regulatory Reporting.

Qualitative and quantitative analysis was performed using the standard formula:
Risk Score = Probability (1-5) × Impact Factor (1-5)

Risks are categorized into three prioritization tiers:
• Low Risk (Score 1-8): Minor operational variances; monitored periodically.
• Medium Risk (Score 9-15): Significant threats requiring formal mitigation strategies and periodic review.
• High Risk (Score 16-25): Critical project and operational threats requiring immediate architectural remediation.

3. Risk Register (Complete Risk Register with All Elements)

The table below details all 10 identified risks according to the required 12-column template:

Risk ID	Risk Description	Category	Prob (1-5)	Imp (1-5)	Risk Score	Priority	Mitigation Strategy	Responsible Party	Cost (INR)	KRIs	Monitoring Frequency
R001	Hardware telemetry overhead introduces latency in core banking transfers (>150ms).	Technical	3	4	12	Medium	Asynchronous decoupled telemetry pipeline; non-blocking OpenTelemetry & Redis queue.	DevOps / Backend Lead	Rs. 25,000	Txn Latency > 100ms (KRI > +15%)	Continuous
R002	Static grid emission factor (713 g/kWh) drifts from regional/hourly CEA grid intensity.	Compliance	4	4	16	High	Dynamic CEA regional API adapter with automated fallback lookup matrix and sync.	Compliance / Data Lead	Rs. 40,000	CEA Grid Factor Drift > 5%	Daily
R003	High concurrency collisions cause double-entry ledger race conditions & lock timeouts.	Technical	2	5	10	Medium	ACID isolation; pessimistic database row locking (SELECT FOR UPDATE) & atomic commits.	Database Architect	Rs. 30,000	DB Lock Contention > 2%	Continuous
R0	eBPF /	Technic	5	4	20	High	Dual-	Backend	Rs.	RAPL	Per Build

04	Kepler hardware counters (RAPL/MSR) blocked in managed cloud container runtimes.	al					engine hybrid architecture: Auto-fallback to PromQL marginal power derivation model.	Lead	35,000	Sensor Unavailability (Bool)	
R005	Cryptographic SHA-256 audit chaining creates sequential serialization bottleneck at high TPS.	Technical	2	3	6	Low	Batched Merkle tree hash aggregation with asynchronous immutable ledger commits.	Security Engineer	Rs. 15,000	Hash Queue Depth > 500	Hourly
R006	JWT token exfiltration or secret key compromise permits fraudulent API transfer requests.	Security	2	5	10	Medium	HTTPS TLS 1.3, short-lived tokens (15m), HMAC-SHA256 secret rotation, IP-pinned auth.	Security Lead	Rs. 20,000	Failed Auth Rate > 3%	Real-time
R007	Non-compliance with SEBI BRSR Core and RBI Green Fintech assurance guidelines.	Regulatory	3	5	15	Medium	Built-in ISO 14064 verified PDF/CSV audit export; automated third-party auditor reconciliation.	ESG Compliance Lead	Rs. 50,000	Audit Discrepancy Count > 0	Weekly
R008	Single-region cloud outage (Render/PaaS) causing service	Operational	3	4	12	Medium	Containerized multi-cloud deployment (Docker + K8s), automated	DevOps Lead	Rs. 35,000	HTTP 5xx Error Rate > 1%	Continuous

	downtime and ledger unreachability.						health check failovers.				
R009	Prometheus scraping failure causes dropped telemetry packets and untracked energy gaps.	Operational	3	3	9	Medium	Prometheus Alertmanager integration, exponential backoff scraper, local cache buffer.	DevOps Engineer	Rs. 15,000	Scrape Target Dropped > 0	Minutely
R010	Cloud hardware profiling costs exceed student project / startup budget thresholds.	Financial	2	3	6	Low	Strict monthly cloud spend caps, local container emulation testing, open-source Kepler.	Project Lead	Rs. 10,000	Monthly Budget Burn > 85%	Weekly

4. Risk Assessment (Analysis of Key Risks with Justification)

Analysis and justification for primary high and medium risks:

1. Risk R004 (eBPF Kernel / Hardware RAPL Inaccessibility - Score: 20, High Priority):
Managed cloud container environments (Render, AWS Fargate, Google Cloud Run) isolate worker containers and block access to /sys/class/powercap and host kernel MSRs. Consequently, raw Kepler eBPF fails to read physical hardware power counters. Because this would halt the entire energy observability feature, it is rated as High Priority. Mitigation: A hybrid fallback engine that derives energy via marginal CPU time when hardware RAPL is unavailable.

2. Risk R002 (Static Grid Emission Factor Drift - Score: 16, High Priority):
The national average grid emission factor in India is 713.0 gCO2/kWh (CEA 2023). However, hourly regional dispatch varies significantly depending on renewable penetration. Relying solely on a static figure across all seasons and cloud regions creates compliance vulnerability under SEBI BRSR and ISO 14064. Mitigation: Dynamic API connectors with regional lookup tables.

3. Risk R001 & R003 (Transaction Latency & Ledger Concurrency Collisions - Scores: 12 & 10, Medium Priority):

Financial core ledgers must satisfy strict latency SLAs (<100ms). Synchronous telemetry writes could cause thread blocking and database lock contention during concurrent payments. Mitigation: Decoupling telemetry through asynchronous background tasks and enforcing ACID row locking for ledger updates.

5. Mitigation Strategies (Detailed Description of Mitigation Approaches)

Mitigation strategies structured across the four PMBOK response frameworks:

1. Risk Avoidance:
• Avoid kernel lockups by decoupling Kepler eBPF from critical banking request paths.
• Avoid race conditions on account balances by enforcing strict ACID isolation and atomic database transactions.

2. Risk Transfer:
• Transfer physical server availability and network failover liabilities to Render Cloud SLA (99.9% compute uptime).
• Transfer Scope 2 methodological compliance risk by using official published Central Electricity Authority (CEA) baselines.

3. Risk Mitigation (Reduction):
• Implement asynchronous background queues (FastAPI BackgroundTasks / Redis) to ensure telemetry overhead remains below 1.2ms.
• Embed SHA-256 cryptographic chaining in every transaction block to prevent tampering.
• Implement JWT tokens with 15-minute expiry, HTTPS TLS 1.3, and rotating secrets to mitigate authentication risks.

4. Risk Acceptance:
• Accept a minor +/-3.8% model variance when running marginal PromQL CPU power estimation instead of physical hardware power meters, formally noting this in ESG compliance disclosures.

Resource and Budget Allocation for Mitigation Actions

Action Item	Engineering Resources	Tools / Infrastructure	Budget (INR)
Async OpenTelemetry & Queue Pipeline	Backend Lead (25 hrs)	Redis, Celery, FastAPI BackgroundTasks	Rs. 25,000
Dynamic Regional CEA Grid Adapter	Data Engineer (30 hrs)	CEA API Scraper, NumPy, Cron Sync	Rs. 40,000
PromQL Marginal Model Fallback	Observability Eng. (35 hrs)	Prometheus Client, Kepler Docker Lab	Rs. 35,000
ACID Lock Isolation & Concurrency Suite	Database Architect (20 hrs)	PostgreSQL, SQLAlchemy, PyTest Suite	Rs. 30,000
Security Hardening (JWT TLS 1.3 Audit)	Security Engineer (15 hrs)	PyJWT, Cryptography, OWASP ZAP	Rs. 20,000
Total Mitigation Investment	125 Engineering Hours	Open-Source & Cloud Infrastructure	Rs. 1,50,000

6. Monitoring Plan (KRIs, Thresholds, and Monitoring Methods)

Key Risk Indicators (KRIs) track metrics to warn of potential threshold breaches before system failures occur. The standard formula applied is:
KRI (%) = ((Current_Observed_Value - Baseline_Value) / Baseline_Value) × 100

Concrete KRI Applications:
• Transaction Latency KRI (Baseline = 100ms): If latency reaches 118ms under peak load, KRI = ((118 - 100) / 100) × 100 = +18%, triggering an alert to scale asynchronous worker threads.
• Telemetry Drop Rate KRI (Baseline = 0.0%): If Prometheus scrape drop reaches 0.8%, a critical alert is dispatched via Prometheus Alertmanager.
• Grid Emission Factor Deviation KRI (Baseline = 713 gCO2/kWh): If local grid carbon intensity reaches 770 gCO2/kWh, KRI = +7.99%, triggering an automated update to the carbon ledger conversion factor.

KRI Monitoring Thresholds Matrix

Monitored Parameter	Baseline	Green (Normal)	Yellow (Warning)	Red (Critical)	Collection Tool
Transfer API Latency	100 ms	< 110 ms (+10%)	110 - 125 ms (+25%)	> 125 ms	Prometheus (http_duration)
CPU Power Draw	15 Watts	< 18 Watts	18 - 25 Watts	> 25 Watts	Kepler / RAPL Exporter
Scrape Failure Rate	0.0 %	< 0.1 %	0.1 % - 0.5 %	> 0.5 %	Prometheus scrape_samples
DB Lock Wait Time	5 ms	< 10 ms	10 - 25 ms	> 25 ms	PostgreSQL pg_stat_activity
JWT Auth Failure Rate	0.5 %	< 1.0 %	1.0 % - 3.0 %	> 3.0 %	FastAPI Security Logs
Cloud CPU Utilization	20 %	< 50 %	50 % - 75 %	> 75 %	Render Container Metrics

7. Management Framework (Escalation Procedures and Contingency Plans)

Incident Escalation Procedures:

• Level 1: Minor (Low Severity) — Yellow warning threshold reached (Latency KRI +12%, 1 scrape missed). Response Time: < 15 minutes. Stakeholders: DevOps Engineer, Backend Developer. Protocol: Automated retries and background queue worker scaling.

• Level 2: Major (Medium Severity) — Red threshold breached (Latency > 130ms, DB lock wait > 25ms, CPU > 80%). Response Time: < 30 minutes. Stakeholders: Backend Lead, Database Architect. Protocol: Automated PagerDuty/Slack notification; non-critical telemetry switches to batch mode.

• Level 3: Critical (High Severity) — Core outage, ledger corruption, authentication token compromise. Response Time: < 5 minutes (Immediate). Stakeholders: Project Lead (Soham Gaikwad), Academic Supervisor (Prof. Kirti Chaudhari). Protocol: Payment gateway locks to read-only; database state restored from immutable cryptographic backup; full post-mortem.

Contingency & Disaster Recovery Plans:

1. RAPL Hardware Probing Failure: If cloud container restrictions block eBPF hardware reading, the engine automatically falls back to marginal PromQL power derivation without interrupting the banking transaction.
2. Database Ledger Inconsistency: The system uses Write-Ahead Logging (WAL) and automated point-in-time recovery to revert to the last verified cryptographic SHA-256 block.
3. Cloud Infrastructure Outage: Complete application containerization via Docker enables instant local redeployment or multi-cloud failover within 3 minutes.

8. Conclusion (Summary of Key Findings and Recommendations)

This Risk Mitigation, Monitoring, and Management Plan provides formal engineering governance for the Green-Finance system. Ten operational risks were identified, analyzed, and evaluated. By introducing asynchronous non-blocking queues, hybrid algorithmic power derivation, strict ACID isolation, and multi-tier monitoring, all critical risks have been reduced to acceptable operational thresholds.

Recommendations for Production Deployment:
1. Migrate from single-instance databases to distributed CockroachDB or PostgreSQL with multi-region replication.
2. Calibrate machine-learning Kepler power estimation models against physical laboratory hardware power meters.
3. Connect real-time webhooks to national grid dispatch centers for live dynamic carbon factor ingestion.